Ethics Audit Report — Haven Advisor

AI Immigration Chatbot · Audit v1.0 · 2026-08-07

System audited	Haven Advisor, live at haven-h1b.com/advisor
Version	MVP v1.0 · prompt `haven-advisor-system` v8/v9 · eval dataset v2 · model `gpt-5-mini`
Audit date	2026-08-07
Evidence baseline	`gpt-5-mini-production-baseline` , 2026-08-04, 10 cases × 2 runs
Auditor	Internal review, Haven
Companion documents	Model Card · PRD · Eval harness
Verdict	**Conditional pass — continue operating, with four conditions.** See §5.

1. Overview of the Audit

1.1 What was audited

Haven Advisor answers U.S. employment-track immigration questions (F-1 → OPT/CPT → H-1B → employment-based green card) for registered Haven users. It is **not a trained model**: it is a composed system — a foundation model (`gpt-5-mini`), prompted and schema-constrained, over a curated 21-document retrieval corpus, wrapped in an 11-stage deterministic guardrail pipeline.

This audit therefore evaluates **the deployed system**, not the base model. Auditing only the base model would miss where nearly all of Haven's ethical exposure actually sits: in the retrieval corpus, the guardrail layer, the rate limit, and the evaluation regime.

1.2 Scope

In scope:

- The full user-path pipeline: rate limiting, moderation, topic classification, guardrail assembly, retrieval, generation, staleness detection, safety addendum, high-risk normalization.
- The knowledge corpus (`source-corpus.ts`) and its update mechanism.
- Community data and case-outcome aggregation, including the k-anonymity implementation (`0019_aggregate_case_outcomes.sql`).
- The evaluation regime: dataset, harness, promotion gate, committed baselines.
- Access controls, profile-data handling, and observability.

Out of scope:

- Formal legal review of unauthorized-practice-of-law exposure. **This audit does not clear Haven legally** and is not a substitute for attorney review (see R8).
- Base-model provenance, training data, and alignment — not observable to Haven.
- Penetration testing and adversarial red-teaming. **No systematic jailbreak testing was performed**; this is itself a finding (F-5).
- Infrastructure security beyond the RLS and consent controls examined.

1.3 Ethical principles evaluated against

Principle	Operational question asked
Fairness & non-discrimination	Does the system perform comparably across user subgroups — and can we even tell?
Transparency & honesty	Does the system's expressed confidence match its actual epistemic state? Are limits disclosed to users, not just to operators?
Accountability & human oversight	Who is responsible when it is wrong? Is oversight real-time or retrospective? Are safety properties verifiable?
Privacy & data governance	Is user and community data collected with consent, minimized, and protected against re-identification?
Safety & non-maleficence	Are the plausible severe harms identified, mitigated, and monitored?
Justice & access equity	Is a scarce resource allocated in a way that tracks need, or in a way that penalizes the most vulnerable users?
Validity & evidential integrity	Is the evidence for the system's safety claims independent and sufficient?

1.4 Method

Direct inspection of source (`service.ts`, `case-stats.ts`, `source-corpus.ts`, `schema.ts`), the SQL aggregation migration, eval fixtures, and committed baseline reports; per-case re-analysis of the reference run; review of the PRD, conversation-design requirements, and intent corpus sort. **All quantitative claims below are recomputed from committed artifacts**, not taken from prior summaries.

1.5 Severity scale

Severity	Meaning
Critical	Active harm occurring, or a safety claim that is false as stated. Blocks continued operation.
High	Plausible path to serious user harm, or an ethical principle that cannot currently be verified. Fix before scaling traffic.
Medium	Real ethical defect with partial mitigation in place. Fix on the current roadmap.
Low	Quality or hygiene issue with ethical implications.

---

2. Summary of Findings

ID	Finding	Principle	Severity
F-1	Subgroup performance is **structurally unmeasurable** — the population most exposed to harm is the least observable	Fairness	**High**
F-2	Staleness protection keys on **corpus age, not source truth** — the system can be confidently and authoritatively wrong within its own safety window	Transparency, Safety	**High**
F-3	Documented safety behavior is carried by a **post-hoc string-patch layer**, not by the model — 60% of answers required patching, deterministically on five topics	Accountability, Safety	**High**
F-4	The **flat 5-conversations/24h cap is regressive** — it binds hardest on users in acute crisis	Justice & access equity	**Medium**
F-5	**Evidential integrity is compromised**: evals authored by the prompt author, judged by the same model family, 10 of 57 cases run, no adversarial testing	Validity, Accountability	**Medium**
F-6	**Community outcome data carries uncorrected selection bias** toward better outcomes	Fairness, Beneficence	**Medium**
F-7	**p95 latency is 25.8s against a 15s target** — worst for the crisis persona	Non-maleficence	**Low–Medium**

---

3. Key Findings

F-1 — Subgroup performance is structurally unmeasurable (Fairness · High)

Finding. Haven cannot produce disaggregated performance metrics by country of birth, preference category, or visa type. This is not a sampling shortfall that a larger run would fix — it is a **schema defect**. The eval fixtures' `profileSnapshot` is a free-form per-case object (`currentStatus` , `i94Expires` , `lastWorkDay` , …) with no structured demographic fields. Only **1 of the 10** cases in the reference run carries an explicit `countryOfBirth` and `preferenceCategory` (India / EB-2).

Evidence. Recomputed from `evals/advisor/fixtures/stage-2-detailed-cases.json` joined against `gpt-5-mini-production-baseline.json` . Pass rate is uniform 100% across all seven category subgroups, but at N=1–2 per subgroup this is an underpowered test, not evidence of fairness. The one signal that *does* vary is the safety-patch fire rate:

Subgroup	Cases	Pass rate	Patch fire rate
H-1B transfer / job change	1	100%	**100%**
I-140 / I-485 / EAD / AP	1	100%	**100%**
EB-1 / NIW self-petition	1	100%	**100%**
H-1B layoff / grace period	2	100%	50%
Visa bulletin / priority dates	2	100%	50%
F-1 OPT / STEM / CPT	2	100%	50%
Safety refusal	1	100%	0%
Standard-risk cases	**0**	**not measured**	—

Why this is an ethical finding and not a metrics gap. Haven's user population skews toward EB-2/EB-3 applicants born in India and China. Those users face the longest backlogs, the most complex visa-bulletin reasoning, and the highest cost of a wrong answer. **The subgroup most exposed to harm is precisely the one whose performance Haven cannot currently observe.** An unmeasured disparity affecting the most vulnerable users is not a neutral absence of data; it is an unfalsifiable fairness claim.

Compounding gap. English-proficiency effects are entirely untested. Non-native phrasing and code-switching are common in this population, and the base model's training distribution is English-dominant. No test exists.

F-2 — Staleness protection keys on corpus age, not source truth (Transparency, Safety · High)

Finding. The Visa Bulletin changes monthly and USCIS policy changes without notice, but the corpus is **manually updated by code change and redeploy** — there is no automated ingestion. The mitigation in place, `detectStaleBulletin()`, refuses month-specific filing conclusions when the corpus is **more than 45 days old**.

The defect: that trigger is a proxy for staleness, not a measurement of it. It fires on *corpus age*, never on an actual diff against the live government source. **A policy that changes on day 3 of a 45-day window will be answered confidently, with authoritative citations, and wrongly — and the system will have no signal that anything is amiss.** Every control that would catch this (citation verification, live retrieval) is roadmap, not shipped.

Why this is a transparency violation, not only a correctness bug. The output contract requires a confidence field and citations to named government URLs. Within the 45-day window, an answer grounded in superseded policy is presented with the *same* confidence and the *same* authoritative citation formatting as a correct one. The user is given no means to distinguish the two. The system's expressed confidence does not track its actual epistemic state, and the citation — traceable to a real USCIS page — actively increases user trust in the stale claim.

Evidence. `source-corpus.ts` carries 12 sources / 21 documents / ~92 chunks with `effectiveDate` values of 2026-03-01 and 2026-07-01; update mechanism is manual. Staleness logic in `service.ts:detectStaleBulletin()`.

F-3 — Safety is carried by a post-hoc patch layer, not by the model (Accountability, Safety · High)

Finding. Required safety language is stapled onto answers after generation by `buildMandatorySafetyAddendum()`. Over 20 sampled answers, **12 required patching — a 60% fire rate.** Every fire means the system prompt did not produce required safety language on its own.

The sharper result. Per-case re-analysis shows this is **not stochastic variation — it is deterministic by topic**:

Fire rate	Cases	Notes fired
100% of runs	6	`h1b-layoff`, `i485-travel` ×2, `cspa`, `cpt`, `niw`
0% of runs	4	—
Anything in between	**0**	—

There is no middle case. `i485-travel` is the worst note (4 of 20 fires, across two different categories).

Why this is an accountability finding. Users are safe today — the patch fires before the answer ships. But the safety property Haven documents is a property of **regex over answer text**, not of model behavior. That layer can only catch failure modes someone already anticipated and wrote a pattern for. A dangerous phrasing that no one predicted, in one of these five topics, passes through untouched. The system is therefore safe against the *known* list and unverified against everything else — and the 60% figure shows the model is actively relying on that layer rather than incidentally backstopped by it.

Aggravating factor. The Advisor sets **no `temperature` and no `seed`**, so output is stochastic. Safety claims rest on a patch layer applied to non-deterministic text.

F-4 — The flat rate cap is regressive under crisis load (Justice & access equity · **Medium**)

Finding. Every user gets 5 conversations per 24 hours, applied uniformly. The cap exists as a cost control, not as a fairness or safety design.

Why this is an equity finding. The users who need the most conversational turns are the ones in acute crisis — the just-laid-off H-1B holder working a 60-day clock, who must reason through termination-date mechanics, transfer timing, filing deadlines, and what does *not* work. That user hits the cap fastest and is harmed most by hitting it. A user with an idle curiosity about a future filing consumes the same allocation and loses nothing by exhausting it. **The cap is uniform in form and regressive in effect: it allocates a scarce safety resource inversely to need.**

This is a legitimate cost decision at Haven's current stage — the audit does not recommend removing it — but it is currently undocumented as an equity trade-off and unmonitored for differential impact.

F-5 — Evidential integrity is compromised (Validity, Accountability · **Medium**)

Finding. Four independent weaknesses undermine the evidence base for every safety claim in the model card:

1. **Author-evaluator conflict.** The eval cases were hand-authored by the same person who wrote the system prompt. The tests risk encoding the prompt's own assumptions rather than user behavior.
2. **Correlated judge.** The LLM judge is `gpt-5-mini` — the same model family as the generator. Shared blind spots go undetected by construction.
3. **Partial execution.** The reference baseline ran **10 of 57** available cases. All **14 standard-risk cases went unexercised**, so routine-question quality is entirely unmeasured.
4. **No adversarial testing.** No systematic jailbreak or prompt-injection testing has been performed against a system whose central safety claim is that it refuses to help conceal facts from USCIS.
5. **No production held-out set.** No evaluation against real (consented, anonymized) user questions exists.

Why this is an ethical finding. The model card asserts a 100% safety-check pass rate. That claim is only as strong as its evidence, and the evidence is self-authored, self-judged, partially executed, and untested against an adversary. **The number is accurate; the confidence it invites is not earned.**

Credit where due. The harness has genuine methodological strengths: worst-run-wins scoring, explicit flaky detection, append-only committed run history, and a promotion gate requiring 100% safety pass across repeats. The weakness is in the dataset's independence, not the harness's rigor.

F-6 — Community outcome data carries uncorrected selection bias (Fairness, Beneficence · **Medium**)

Finding. Aggregate case statistics are drawn from users who chose to contribute outcomes. Contributors are self-selected toward the more engaged, and toward those whose situation reached a resolvable outcome worth reporting. Users who lost status, left the country, or disengaged are systematically less likely to appear.

Effect. "What did people like me do after a layoff?" can under-represent the worst outcomes — precisely the outcomes a user in crisis most needs weighted correctly. The k-anonymity floor and the consent restriction are **privacy** controls; neither corrects **representativeness**.

Existing mitigation is partial: every community result is labeled "anecdotal," numbers are computed by SQL rather than generated by the model, and segments below k=5 return "not enough data" rather than an invented trend. These are meaningful controls. None addresses who is in the sample.

F-7 — Latency worst for the users least able to tolerate it (Non-maleficence · Low–Medium)

Finding. p95 end-to-end latency is **25.8s against a stated 15s target** (mean 21.3s, max 31.4s) — roughly 70% over. The 11-stage pipeline runs on serverless infrastructure.

Ethical dimension. This is not a safety failure, but the persona least tolerant of a 26-second wait is the post-layoff user in acute distress. Slowness is a real, if bounded, harm to a user in crisis, and it raises abandonment risk at exactly the moment the tool is most valuable.

---

4. Controls Working Well

A fair audit records what holds. These are genuine strengths and should be protected against regression:

Control	Assessment
Numbers never come from the model	Case statistics are computed in SQL and inserted verbatim; the model only phrases them. This structurally eliminates the most dangerous hallucination class in the product. **Strong design.**
k-anonymity + consent gating	`MIN_CELL = 5` enforced in both the RPC and application code; `source in ('first_party','consented')` — scraped and prototype rows are never counted. Sub-floor cells lump into `other`, shown only if `other` also clears the floor. **Correctly implemented.**
Profile-leak protection	Profile facts enter the prompt only when the question calls for them; user-stated dates override stored dates; `stripUnrequestedPriorityDate()` removes unrequested profile dates from output. **Directly addresses a real privacy harm.**
Refusal as a feature	Stale bulletin → refuse; concealment request → refuse + preserve records + counsel; insufficient data → "not enough data." The system is designed to decline rather than guess.
Scope discipline	Family-based immigration routing is conditional on the user's actual visa track rather than keyword matching — a more careful boundary than most products draw.
Version control and traceability	Prompt versioned in Langfuse; corpus documents carry `versionLabel` and `effectiveDate`; eval history is append-only and committed. Every claim in the model card traces to a named run.
Documentation honesty	The model card discloses unflattering findings (60% patch dependence, latency miss, N=10 of 57, unmeasurable fairness) rather than omitting them.

---

5. Recommendations

Ordered by ethical urgency, not engineering convenience.

#	Recommendation	Addresses	Priority
R1	**Add structured demographic fields to eval fixtures** (`countryOfBirth` , `preferenceCategory` , `visaType`), backfill all 57 cases, then report **disaggregated** pass and fire rates by subgroup. This is a schema change and a prerequisite — no fairness analysis is possible until it lands.	F-1	**Immediate**
R2	**Ship live USCIS/DOS retrieval, then the citation verifier** (confirming quoted text actually appears in the cited source), in that order. Until live retrieval ships, **tighten the staleness window and surface corpus age to the user** in date-sensitive answers, so recency is visible rather than assumed.	F-2	**Immediate**
R3	**Drive the patch fire rate down, starting with `i485-travel`** (4 of 20 fires, two categories). Target: every note at 0% across a decent sample, at which point the corresponding patch becomes a deletion candidate. Track the fire-rate delta on every prompt change — a rise means the new prompt is *less* compliant even if all checks still pass.	F-3	**Immediate**
R4	**Run the full 57-case dataset**, including all 14 standard-risk cases, on every promotion.	F-5	**Near-term**
R5	**Commission adversarial testing** — systematic jailbreak and prompt-injection attempts against the concealment-refusal and unauthorized-work guardrails, by someone who did not write the prompt.	F-5, F-3	**Near-term**
R6	**Replace the judge with a different model family** to break generator/judge error correlation.	F-5	**Near-term**
R7	**Add a held-out set of real consented, anonymized production questions**, curated by someone other than the prompt author.	F-5	**Near-term**
R8	**Obtain attorney review** of the disclaimer and refusal architecture. Required before any paid tier — payment changes the risk posture from informational tool to purchased service.	Scope limit §1.2	**Before monetization**
R9	**Make the rate limit need-aware.** Options: exempt or extend the cap for detected crisis contexts (layoff/grace-period topics), or let follow-ups in an active crisis thread draw on a separate allowance. At minimum, document the cap as an explicit equity trade-off and monitor 👎 reasons for differential impact.	F-4	**Near-term**
R10	**Disclose community-data selection bias to users** in the answer surface — the "anecdotal" label should also convey *who is missing* from the sample, not just that the sample is informal.	F-6	**Near-term**
R11	**Bring p95 latency under the 15s target**, prioritizing the layoff/crisis path.	F-7	**Near-term**
R12	**Add English-proficiency test cases** — non-native phrasing and code-switched questions — to the eval set.	F-1	**Near-term**

Standing constraints (do not violate while implementing the above): never promote a prompt version on a single eval run; never loosen a guardrail to improve latency or token cost; never add a feature that lets the model produce a statistic.

---

6. Verdict and Conditions

Conditional pass — continue operating.

The system's core architecture is ethically sound. The design assumption that *the model will sometimes be wrong* — expressed in SQL-computed numbers, schema-constrained output, refusal paths, and layered guardrails — is the correct assumption for this risk domain, and it is implemented, not merely stated. No finding in this audit indicates active user harm.

Operation should continue subject to four conditions:

1. **No traffic scaling** until R1 (fairness measurability) and R2 (staleness) are underway. Growing usage on an unmeasurable fairness baseline compounds an unverified risk.
2. **No paid tier** until R8 (attorney review) is complete.
3. **No guardrail relaxation** in service of latency or cost, including under commercial pressure.
4. **Fire-rate delta reviewed on every prompt promotion**, treated as a blocking signal, not an informational one.

Two findings would escalate to Critical if left unaddressed as traffic grows: F-1, because an unmeasurable fairness property affecting the most exposed subgroup becomes an active harm at scale; and F-2, because the probability that a policy changes mid-window approaches certainty as the window repeats.

This audit is an internal engineering and ethics review. It is not a legal opinion and does not clear Haven of unauthorized-practice-of-law exposure. Haven provides information, not legal advice.